MERROWFIELD DIGITAL

Playbook: Ransomware

Document Playbook 02 | Rev 3 | Effective 9 February 2026 | Owner: Security Operations | Review cycle: 12 months

1. What this playbook covers

This playbook covers malicious encryption of systems or data, with or without data being taken first, and the extortion demands that follow. It is used by the Security Analyst who investigates, from the first alert until the incident is closed.

2. How it is usually recognised

- an endpoint alert for mass file encryption
- files renamed with an unfamiliar extension, or ransom notes in folders
- shadow copies deleted or backup jobs failing without explanation
- an extortion email, or a post naming Merrowfield on a leak site

3. The first hour

1. Isolate the affected network segments to stop the spread.
2. Disable compromised accounts and reset domain administrator credentials.
3. Protect the backups: confirm an offline copy exists and keep it out of reach of the affected domain.
4. Leave encrypted hosts powered on and isolated, so evidence in memory survives, unless they are still spreading the encryption.
5. Invoke business continuity for the services that are down.
6. Do not contact the attackers and do not pay. Legal informs the law enforcement liaison.

4. Evidence to preserve

- the ransom note and samples of encrypted files
- endpoint telemetry and memory images from affected hosts
- firewall and proxy logs covering the days before encryption
- screenshots of any leak-site post, taken by the threat intelligence team

5. Establishing the facts a report needs

Whatever is decided, the decision needs these facts, established as early as they can be:

- which systems and which data were encrypted
- whether data was staged or taken before encryption - whether exfiltration is confirmed
- how long customer-facing services were unavailable, and how many customers that affected
- the direct financial loss so far
- the state of the backups, and how long restoration will take

6. Reporting

Which reporting procedures apply is settled from the incident's facts by the rules in Plan 01, section 8, and each procedure's deadlines are read from that procedure. This playbook sets no deadline of its own, and the decision belongs to the Data Protection Officer.

A long outage, a large number of customers affected or a large direct loss makes a ransomware incident significant under Procedure 02 whether or not personal data was taken.

7. What affected customers should do

When customers are told, the notice gives them these steps, in this order:

- You do not need to change anything on your account unless we tell you to.
- Be alert to emails, calls or messages that quote your order details and ask for payment or your password. Merrowfield will contact you only from its usual addresses.
- If a service was unavailable, your orders are safe and will be processed as systems are restored; you do not need to place them again.

8. Closing the incident

Restore from clean backups, rebuild what cannot be trusted, verify integrity before reconnecting, and review how the attacker moved between segments.